Passing the user's identity from an agent to a gateway

Same user, same tool, same policy. What changed was how the agent got the token it presented to the Gateway.

Path A — managed harness: failed at the agent → Gateway hop

1 User
Signs in (OAuth 2.0 / OIDC)

→ sign in

2 Amazon Cognito
Issues a JWT access token

→ JWT

3 Harness
Accepts the user's JWT (inbound). Calling the Gateway is configured as a *separate outbound OAuth step* (user federation).

✗ error

Outbound OAuth step
Failed: `You must provide a ResourceOauth2ReturnUrl`, even with a default return URL configured. The tool failed to load.

Path B — Runtime agent that forwards the user's token: worked

1 User
Signs in

→ sign in

2 Amazon Cognito
JWT access token `sub` `client_id` `scope`

→ Bearer JWT

3 AgentCore Runtime
JWT authorizer (`CUSTOM_JWT`). `Authorization` is **allow-listed**, so the agent code can read it.

→ same JWT

4 AgentCore Gateway
Header forwarded unchanged. Validates the JWT, then asks the policy engine.

⇒ evaluate

5 Cedar policy
Caller + tool + an input the tool takes (a `year`). No matching permit = deny.

→ allow

6 AWS Lambda
Runs only when allowed.

Observed results (Path B, same user, same tool)

Call	Result
Year 2025	**ALLOW — data returned**
Year 2023	**DENY** — JSON-RPC `-32002`, "denied by default", **HTTP 200**
Lambda log	Ran for the allowed call, not for the denied one (CloudWatch)
Access token	Had `sub`, `client_id`, `scope`; no email or name

Takeaways

- Authentication (Cognito) and authorization (Cedar) are separate controls.
- If the user and identity provider are the same, forward the token; don't fetch a second one.
- Check the response **body** for a denial, not the HTTP status.
- The rule stays outside the model, and not only inside the tool code.
- Test the denial path, not just the success path.
- AgentCore CLI 0.31.1: dependencies come from `pyproject.toml`, not `requirements.txt`.

Learning prototype in a personal AWS account, built while learning with Claude (Claude desktop app). No client or proprietary data. Values as observed in October 2026. Why the harness path fails is the author's reading of the error, not a confirmed root cause.